SUPPORT ÉTUDIANT

DSP2 et Open Banking

Jour 3 : Le paiement initié

Chrisvene MPANDZOU

chrisvene.mpandzou@a2mtech.com

M2 SIB · 2026 – 2027

Sommaire

Repères de lecture du polycopié

01 Introduction & objectifs 3

02 S1 · Principe du paiement initié 5

03 S2 · Flux PISP détaillé 9

04 S3 · Architecture SI PISP 14

05 S4 · Applications et cas concrets 20

Introduction & objectifs

ACCUEIL

Intro & objectifs

Le Jour 1 a posé les fondements, le Jour 2 a démonté l'API et sa sécurité. Le Jour 3 met tout en mouvement : le paiement lui-même, celui qu'un tiers initie au nom du client, sans carte bancaire.

FIL ROUGE

Mardi, 20 h 40. Lyam finalise une commande sur le site d'un marchand. Le bouton ne dit plus « carte bancaire » mais **« Payer par virement »**. Il choisit Banque Est, valide dans son application bancaire, et la commande est payée. **Aucune carte n'a été saisie.** Le Jour 3 explique ce qui vient de se passer.

RAPPEL

Là où l'on en est

- **Jour 1 — les rôles.** Trois rôles de tiers définis : l'**AISP** (lecture des comptes), le **PISP** (initiation de paiement) et le **CBPII** (confirmation de fonds).
- **Jour 2 — l'accès sécurisé.** Comment un tiers s'authentifie (mTLS, OAuth2), obtient une autorisation (consentement) et présente un jeton à chaque appel.
- **Déjà étudié — l'AIS.** Le cas le plus simple : lire les comptes, sans jamais déplacer d'argent.

Pourquoi le PISP est « le plus délicat »

L'AIS lit : une erreur affiche un mauvais solde. Le PISP **écrit** : une erreur déplace de l'argent. La conséquence change tout — la SCA est obligatoire à chaque paiement, l'idempotence devient critique, la réconciliation avec le règlement ne pardonne pas. C'est ce qui rend le PISP un excellent terrain d'architecture.

Ce qu'il faut avoir retenu des jours 1 et 2

Les rôles ASPSP / TPP / PISP, la chaîne Gateway → consentement → IAM → core, le parcours de redirection, et les mécanismes OAuth2 / mTLS / SCA. Le PISP réutilise tout : on ne redéfinit plus, on applique à un paiement.

APERÇU

Le parcours du Jour 3, en une image

On part du principe économique (pourquoi un tel paiement existe), on suit un flux complet du clic au

règlement, on descend dans le SI qui le rend possible.

S1 — Principe du paiement initié

Qu'est-ce qu'un paiement initié par un tiers ? Transfert compte à compte, alternative à la carte, acteurs Client → PISP → Banque → Marchand.

S2 — Flux PISP détaillé

Cinq étapes : consentement, redirection SCA, initiation, confirmation, règlement. Et les comparaisons PISP vs carte, PISP vs wallet.

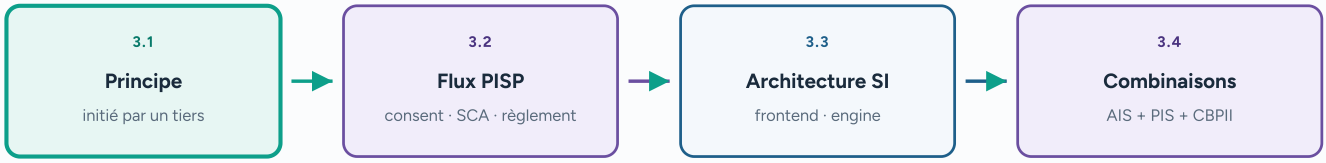
S3 — Architecture SI PISP

Frontend marchand, backend PISP, API bancaire, core payment engine. Contraintes de disponibilité, latence, gestion des rejets.

S4 — Combiner les API

AIS + PIS + CBPII ne sont pas trois produits mais trois briques. Quatre motifs d'assemblage, avec les schémas d'appels qui les rendent concrets.

Fil du Jour 3



OBJECTIFS PÉDAGOGIQUES

À l'issue du Jour 3, l'étudiant sait…

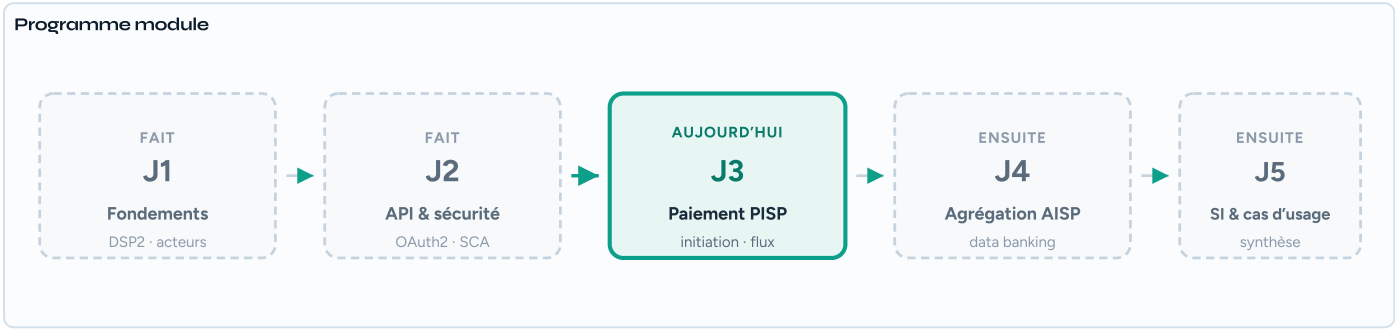
- **Définir** un paiement par initiation : un transfert compte à compte déclenché par un tiers agréé, au nom et avec l'authentification du client, sans carte.
- **Décrire** le flux PISP complet : consentement, redirection SCA, initiation, confirmation, règlement — et nommer les messages échangés à chaque étape.
- **Comparer** PISP, carte bancaire et wallet : coût, garantie, sécurité, expérience, cas d'usage.
- **Cartographier** l'architecture SI d'un PISP : frontend marchand, backend, API bancaire, core payment engine, et leurs contraintes (disponibilité, latence, rejets).
- **Combiner** AIS, PIS et CBPII pour concevoir un cas d'usage réel : quel appel avant quel autre, et quel risque assumer à chaque maillon.
- **Identifier** les notions critiques du PISP : idempotence, statut de paiement, gestion des rejets, anti-fraude, réconciliation.

FIL DE SÉANCE

Parcours

CURSUS

Trajectoire des 5 jours



02 · S1 · PRINCIPE DU PAIEMENT INITIÉ

S1 - Principe du paiement initié

QU'EST-CE QU'UN PAIEMENT INITIÉ ?

Principe du paiement initié

Avant de plonger dans les flux et l'architecture, il faut comprendre *ce qu'est* un paiement initié par un tiers, en quoi il diffère d'un paiement par carte, et pourquoi il existe.

FIL ROUGE

Lyam a trop souvent vu sa carte refusée pour des plafonds atteints ou des authentifications ratées. Pour ce paiement, le marchand lui propose une autre voie : **un virement direct depuis son compte**, validé dans l'application de sa banque. Pas de numéro de carte à saisir.

DÉFINITION

Le paiement par initiation, mot à mot

> **Paiement par initiation** *(Payment Initiation)* : un tiers agréé déclenche, au nom et pour le compte du client, un virement d'un compte de paiement vers un bénéficiaire.

- **un tiers agréé (le PISP)** — c'est lui qui déclenche, jamais la banque ni le marchand.
- **au nom et pour le compte du client** — le PISP n'agit jamais pour lui-même et ne détient jamais les fonds.
- **un virement d'un compte de paiement** — on quitte le monde de la carte : les fonds voyagent par virement (SCT, SCT inst).
- **sur ordre du client** — l'authentification forte (SCA) est la contrepartie : sans elle, pas d'initiation valide.

Le PISP et la carte : deux mondes

Un paiement carte passe par un **réseau de cartes** (Visa, Mastercard). Un paiement PISP passe par un **système de virements** (SEPA : SCT et SCT instantané). C'est la première distinction à fixer : le PISP est un canal de compte à compte, pas un substitut technique à la carte sur le même rail.

MÉCANIQUE

Un virement, trois acteurs additionnels

Un virement « classique » est déjà un transfert compte à compte. Ce que le PISP ajoute, c'est la capacité de le déclencher *depuis le site du marchand*, sans que Lyam quitte son parcours d'achat pour aller faire un virement manuel.

ACTEUR	RÔLE DANS UN VIREMENT MANUEL	RÔLE AVEC UN PISP
Client (Lyam)	Saisit le virement dans son appli bancaire	Clique « payer » chez le marchand, valide la SCA
Banque (ASPSP)	Reçoit l'ordre de Lyam	Authentifie Lyam, exécute le virement ordonné par le PISP
Bénéficiaire (marchand)	Attend un virement sans lien direct	Reçoit un virement rattaché à une commande
PISP	**N'existe pas**	**Déclenche l'ordre au nom de Lyam, sans toucher aux fonds**

IDÉE DIRECTRICE

Le PISP ne crée pas d'argent, ne détient pas d'argent, ne transporte pas d'argent. Il crée un *ordre de virement authentifié* que la banque du payeur exécute.

Ne pas confondre PISP, PSP et ASPSP

Le **PISP** est un *type* de PSP (comme l'AISP et le CBPII). L'**ASPSP** est la banque qui tient le compte. Un établissement peut cumuler plusieurs agréments, mais chaque service qu'il rend relève d'un rôle précis. Cette clarté est la clé de tous les audits.

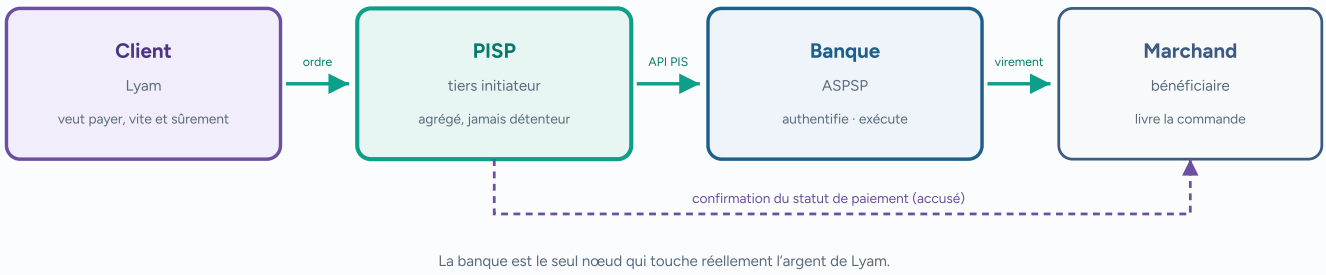
ACTEURS

Le quadruple : Client → PISP → Banque → Marchand

On retient une chaîne à quatre : le client, le PISP, la banque et le marchand. Chacun a un intérêt propre — et

c’est la divergence ou la convergence de ces intérêts qui structure le modèle.

Chaîne des acteurs d’un paiement initié



La banque est le seul nœud qui touche réellement l’argent de Lyam.

Le client

PAYEUR

Donne un ordre de paiement, réalise la SCA chez sa banque. S’il ne valide pas, rien ne part. Il garde la main à chaque étape.

Le PISP

PAYMENT INITIATION SERVICE PROVIDER

Relie marchand et banque, prépare l’ordre, déclenche l’API de paiement, propose le parcours de SCA. **Jamais détenteur** des fonds.

La banque

ASPSP · TIENT LE COMPTE

Authentifie le client, vérifie le compte et la provision, exécute le virement. Elle est responsable de la tenue de compte.

Le marchand

BÉNÉFICIAIRE · COMMERÇANT

Propose le bouton de paiement, reçoit le paiement sur son compte (directement ou via un compte de collecte), livre la commande selon le statut.

POSITIONNEMENT

Une alternative à la carte — pas un doublon

Le paiement initié n’a pas été conçu pour tuer la carte, mais pour couvrir des cas où la carte est coûteuse, refusée ou inadaptée.

CAS D’USAGE	POURQUOI LE PISP EST PERTINENT
Plafond carte atteint	Le compte a de la provision : le virement passe là où la carte bloque
Client sans carte	Non bancarisé en carte, mais titulaire d’un compte de paiement
Panier très élevé	Pas de limite assimilable au plafond carte
Marchand à faible marge	Le virement peut coûter moins cher que la commission carte
Réduction du risque de fraude	**La SCA a lieu chez la banque du payeur, dans son appli habituelle**

Mais aussi : des limites réelles

Le paiement initié **n'est pas réversible** comme un paiement carte contesté : la protection *chargeback* n'existe pas nativement. Il exige une SCA à chaque paiement, ce qui ajoute de la friction. Et il dépend de la disponibilité de l'API bancaire. Un marchand doit donc garder plusieurs moyens de paiement : le PISP complète, il ne remplace pas.

COURS — PISP VS CARTE : L'ÉCART EN PROFONDEUR

CRITÈRE	CARTE	PISP
Rail	Réseau carte (Visa/MC)	Virements SEPA (SCT / SCT inst)
Porteur	Instrument (« la carte »)	Compte de paiement (IBAN)
Rails de traitement	Autorisation · clearing · settlement	Exécution · compensation · règlement SEPA
Contestation	Chargeback / impayé	Recours SEPA, pas de chargeback « à la carte »
Coût marchand	Commission interbancaire + réseau	Souvent plus faible (virement)
Friction	**Faible (enregistrement, tokenisation)**	**SCA par paiement : plus de friction**

Cette comparaison annonce la question de la comparaison avec le **wallet** (S2) : le wallet est une *enveloppe* qui peut contenir une carte *ou* déclencher un paiement de compte. Le PISP est l'un des rails qu'un wallet peut utiliser.

RATIONNEL

Pourquoi la DSP2 a-t-elle créé le PISP ?

La DSP2 poursuit trois objectifs (vus au Jour 1 : concurrence, innovation, protection). Le PISP les incarne tous les trois :

01

Concurrence

> *« Pourquoi devrais-je passer par un terminal carte ou une appli bancaire pour payer un marchand ? »*

Le PISP ouvre un canal de paiement alternatif, en dehors des réseaux cartes, avec ses propres acteurs et sa propre concurrence.

02

Innovation

> *« Payer en un clic depuis un site, sans saisir de carte : c'est nouveau ? »*

Le PISP rend le virement utilisable dans un parcours e-commerce, ce qui ouvre des modèles (paiement par lien, paiement de facture, collecte).

03

Protection

> *« Le marchand ne verra jamais mes identifiants ni ma carte. »*

Le client reste authentifié chez sa banque, dans son environnement habituel : le tiers n'accède jamais aux secrets d'authentification.

SÉQUENCE SUIVANTE

Maintenant, déroulons le flux

On sait ce qu'est un paiement initié et qui y participe. La S2 suit le paiement dans le temps, du consentement au règlement, et compare PISP, carte et wallet.

03 · S2 · FLUX PISP DÉTAILLÉ

S2 · Flux PISP détaillé

DU CLIC AU RÈGLEMENT

Flux PISP détaillé

Un paiement initié se déroule en cinq temps : consentement, redirection SCA, initiation, confirmation, règlement. On les suit un par un, puis on compare PISP, carte et wallet.

FIL ROUGE Lyam a cliqué sur « Payer par virement ». L'écran va changer plusieurs fois : le site du marchand, puis une page de Banque Est pour s'authentifier, puis un retour. Derrière ces changements d'écran, il y a cinq étapes précises.

VUE D'ENSEMBLE

Les cinq étapes du flux PISP

On distingue cinq étapes. Chacune correspond à un acteur qui « tient le stylo » et à un message précis.

#	ÉTAPE	ACTEUR PRINCIPAL	RÉSULTAT
1	Consentement client	PISP + client	Intention de payer + consentement de paiement
2	Redirection SCA	Banque (ASPSP)	Client authentifié dans son environnement bancaire
3	Initiation du paiement	PISP	Ordre de virement déposé, idempotent
4	Confirmation	Banque + PISP	Statut : accepté, en attente, rejeté
5	**Règlement**	**Banques + SEPA**	**Fonds transférés, commande livrée**

1 Le consentement client

Qui initie : **le client** (Lyam) + le PISP



Le consentement PIS diffère radicalement de l'AIS. En AIS, un consentement couvre une *période* et plusieurs lectures. En PIS, un consentement couvre **un paiement** : montant, bénéficiaire, devise, motif. Un paiement = un consentement.

Ce que contient un consentement PIS

- **Montant** et devise ;
- **Bénéficiaire** (IBAN ou identifiant, jamais modifiable après la SCA) ;
- **Motif** (référence de commande — essentiel pour le rapprochement) ;
- **Compte débiteur** (choisi ou implicite) ;
- **Validité** courte : le paiement doit être initié vite, sinon on recommence.

La première étape est aussi celle où le PISP vérifie qu'il a bien un **agrément en cours** et que le client est authentifiable. Ce n'est pas encore un virement : c'est l'acte de vouloir payer.

2 La redirection SCA

Qui authentifie : **la banque (ASPSP)**



Point clé : le client est redirigé vers **sa banque** pour s'authentifier fortement. Le PISP ne collecte jamais les secrets du client. Il propose une redirection (ou, si la banque le permet, une authentification embarquée ou découplée). Mais le principe reste : la **SCA est faite par le monde bancaire**.

A — Redirection

Le PISP renvoie vers l'ASPSP avec un identifiant de consentement et un paramètre d'état (protection contre les attaques cross-site).

B — Authentification forte

Le client réalise la SCA chez sa banque : code, notification push, biométrie, boîtier. Trois facteurs au choix (connaissance, possession, inhérence), deux combinés.

C — Confirmation du consentement PIS

La banque affiche le détail du paiement (montant, bénéficiaire) et demande validation. Le client ne peut pas le modifier à ce stade.

D — Retour + code

La banque émet un code d'autorisation que le PISP échange pour obtenir les droits d'initier ce paiement précis.

Penser SCA avant de penser paiement

Un PISP qui ne sait pas orchestrer la SCA tourne à vide. Le flux de paiement dépend du mécanisme d'authentification du pays et des banques (redirection, intégration, découplée). C'est souvent le travail d'intégration le plus lourd du projet.

COURS — LES TROIS MODÈLES DE SCA EN PISP

MODÈLE	OÙ SE FAIT LA SCA	AVANTAGES / LIMITES
Redirection	Chez l'ASPSP	Universel ; rupture d'expérience (changement d'app)
Intégration	Dans l'expérience du PISP	Fluide ; dépend du plugin banque, responsabilité plus lourde
Découplée	**Dans l'app bancaire**	**Excellent sur mobile ; complexe, pas universel**

3 L'initiation du paiement

Qui initie : **le PISP** (appel à l'API PIS)



Le PISP appelle l'API PIS de la banque. C'est là que naît l'ordre de virement. Deux qualités techniques font la différence ici : l'**idempotence** et la **traçabilité**.

L'idempotence

Chaque initiation porte un identifiant unique. Si le PISP renvoie la requête (timeout, réseau), la banque reconnaît l'identifiant et **ne crée pas un second virement**. Sans idempotence, un simple retry débite deux fois Lyam.

La référence marchand

Le motif du virement contient la référence de commande. C'est ce qui permet au marchand de rapprocher un virement reçu et une commande. Sans référence, la trésorerie devient un cauchemar.

EXEMPLE — APPEL D'INITIATION PIS (ILLUSTRATIF)

```
POST /v1/payments/sepa-credit-transfers
Content-Type: application/json
Authorization: Bearer eyJhbGciOi...
X-Request-ID: 8f3a-commande-20458

{
  "debtorAccount": { "iban": "FR76...0388" },
  "instructedAmount": { "currency": "EUR", "amount": "89.90" },
  "creditorAccount": { "iban": "FR14...6241" },
  "creditorName": "Atelier Verre & Cie",
  "remittanceInformationUnstructured": "CMD-20458"
}
```

La réponse ne dit pas « payé », elle dit **« reçu »** avec un statut. Le vrai résultat viendra à l'étape suivante.

4 La confirmation (le statut)

Qui confirme : **la banque** → le PISP → le marchand



Le PISP n'a pas de certitude immédiate. Il interroge le **statut du paiement** jusqu'à obtenir un état définitif. C'est la partie que négligent les implémentations naïves : elles traitent la réponse d'initiation comme un paiement réussi.

STATUT PIS	SIGNIFICATION	CE QUE FAIT LE MARCHAND
RCVD	Reçu	Attend, ne livre pas encore
PDNG	En cours d'exécution	Attente, polling
ACSC / ACCP	Accepté / réglé	Peut livrer la commande
RJCT	Rejeté	Propose un autre moyen de paiement
CANC	**Annulé**	**Traite comme un abandon**

Polling et notification

Le PISP peut interroger le statut (polling) ou — selon les API — recevoir un événement. Les deux doivent être **idempotents** et cohérents : un double accusé ne doit pas générer une double livraison. C'est précisément le point à vérifier dans son implémentation.

5 Le règlement

Qui règle : **les banques + SEPA** (le PISP s'efface)



Une fois l'ordre exécuté, l'argent circule : du compte de Lyam vers le compte du marchand, par le rail SEPA. Le PISP n'y touche plus. Il a déclenché ; la banque et l'infrastructure de paiement exécutent.

01 **Exécution** — la banque de Lyam débite son compte et émet le virement.

02 **Compensation** — le virement est présenté au système SEPA, puis au bénéficiaire.

03 **Règlement** — les banques se règlent entre elles, via les mécanismes de règlement interbancaire.

04 **Crédit** — le compte du marchand est crédité ; la référence permet le rapprochement de la commande.

RAIL	DÉLAI INDICATIF	IMPLICATION POUR LA COMMANDE
SCT (virement standard)	J+1 ouvré	La commande attend le crédit ou est livrée sous réserve
SCT Instantané	**Quelques secondes**	**Livraison quasi immédiate possible, comme une carte**

Conséquence pour le marchand

Le PISP est excellent quand le règlement est instantané : le marchand sait en quelques secondes s'il peut livrer. Avec un SCT classique, il doit choisir entre attendre le crédit (friction) ou livrer sous réserve (risque). La stratégie de livraison dépend du rail, pas seulement du PISP.

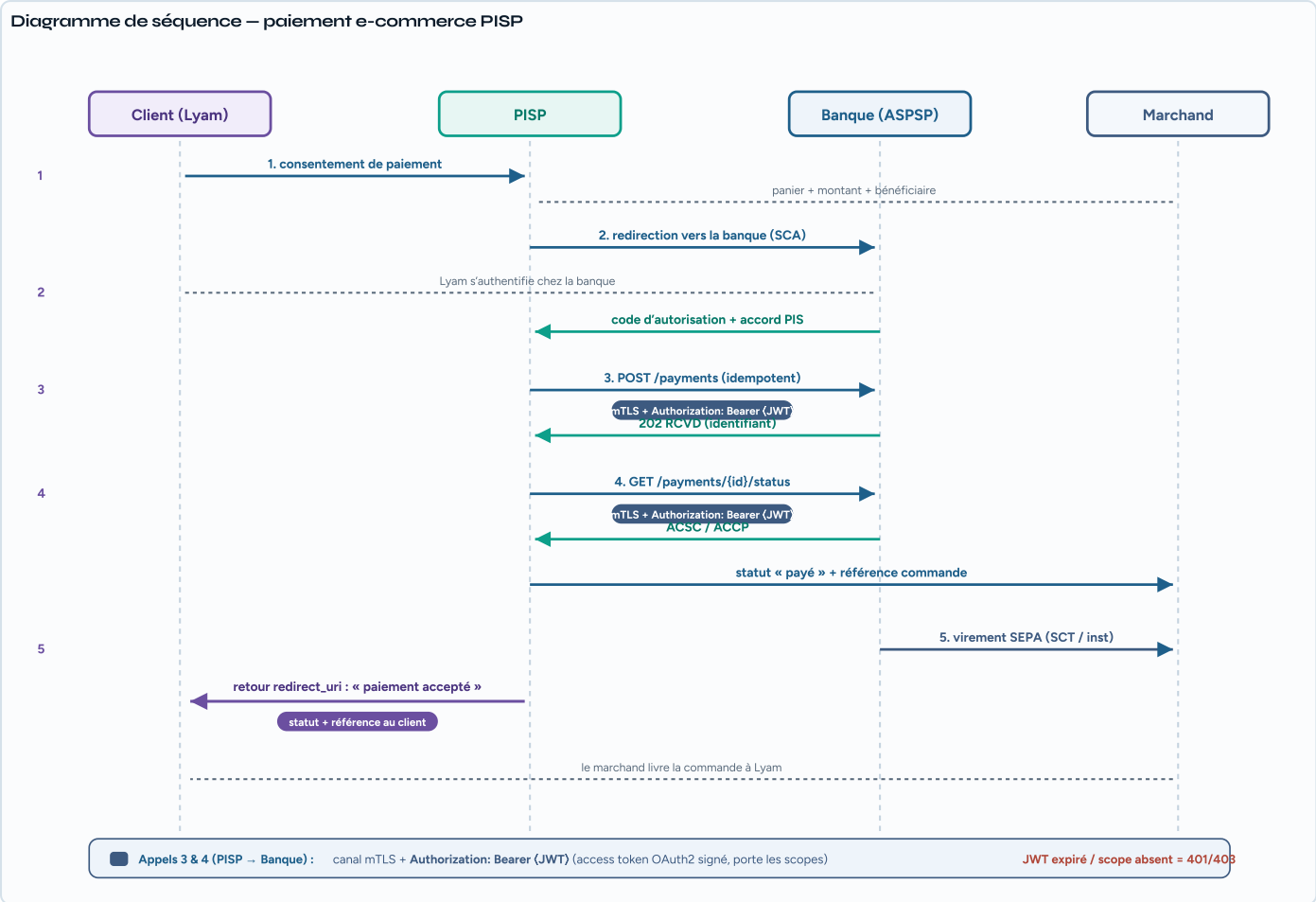
SYNTHÈSE

Le flux complet en un diagramme

Ce diagramme réunit les cinq étapes et les acteurs principaux. C'est le squelette à garder en tête pour tout projet PISP.

On y voit aussi le **retour au client** : une fois la SCA faite, le navigateur de Lyam est renvoyé vers le PISP (`redirect_uri`) avec le résultat — la page de confirmation « paiement accepté » et sa référence de

commande. Sans ce message final, le client ne sait pas si son paiement a abouti.



Le piège du « fire and forget »

Beaucoup d'implémentations s'arrêtent après le `202 RCVD`. C'est faux : **reçu ≠ payé**. La confirmation (étape 4) et le règlement (étape 5) sont des étapes distinctes, chacune porteuse d'échec possible.

COMPARAISONS

PISP vs carte vs wallet

Trois moyens de payer, trois logiques. Il faut explicitement de comparer le PISP à la carte et au wallet : c'est la grille qui permet de choisir le bon canal.

CRITÈRE	CARTE	PISP	WALLET
Support	Instrument physique/virtuel	Compte de paiement (IBAN)	Application / enveloppe
Rail	Réseau carte	Virements SEPA	Variable (carte, compte, solde interne)
Qui tient l'argent	Émetteur de carte	Banque du payeur	Opérateur du wallet
Contestation	Chargeback	Recours SEPA, pas de chargeback	Selon le rail sous-jacent
Friction	Faible	SCA par paiement	Faible (jeton enregistré)
Concurrence	**Réseaux cartes**	**Hors réseau carte**	**Peut contourner la carte**

PISP vs carte

PISP : virement de compte à compte, souvent moins cher pour le marchand, pas de chargeback, dépend de la SCA. Carte : rail mature, contestation protégeant le consommateur, couverture internationale.

PISP vs wallet

Le **wallet** est une enveloppe (identité, moyen de paiement, fidélité). Il peut déclencher un *paiement PISP* si son concepteur l'a prévu. Le PISP est donc un *rail* que le wallet peut utiliser — pas un concurrent direct dans tous les cas.

Le wallet n'est pas un rail

Attention à la confusion : un wallet mobile ou un wallet marchand n'est pas un « rail de paiement », c'est une interface qui s'appuie sur un rail (la carte tokenisée, le compte, etc.). Le PISP est un rail. Cette distinction est reprise au Jour 4 (AISP) et au Jour 5 (Open Finance & wallets).

SÉQUENCE SUIVANTE

Qui construit quoi ?

Le flux est posé. La S3 regarde l'architecture de celui qui le met en œuvre : le PISP, entre le site marchand et l'API bancaire. Frontend, backend, core payment engine, et les contraintes non négociables.

04 · S3 · ARCHITECTURE SI PISP

S3 - Architecture SI PISP

LE SI QUI REND LE PAIEMENT POSSIBLE

Architecture SI PISP

Entre le bouton « Payer par virement » et le compte de Lyam, il y a une chaîne de composants. Comprendre qui fait quoi, et sous quelles contraintes, c'est savoir où placer la responsabilité quand un paiement échoue.

FIL ROUGE

Lyam clique sur « Payer par virement » chez Atelier Verre & Cie. En une poignée de secondes, une requête traverse quatre composants avant que l'argent ne bouge. Chacun a un rôle, et chacun peut être le maillon qui casse. La S3 ouvre le capot.

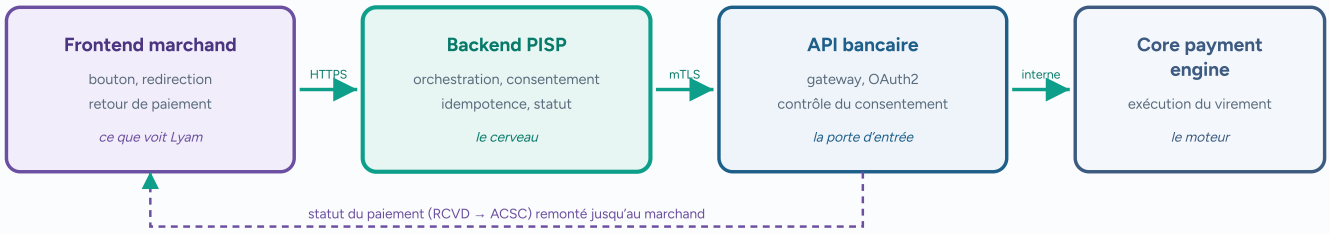
VUE D'ENSEMBLE

Les quatre composants d'une chaîne PISP

Un paiement initié traverse quatre couches : le **frontend marchand** (ce que voit Lyam), le **backend PISP** (le cerveau qui orchestre), l'**API bancaire** (la porte d'entrée de la banque) et le **core payment engine** (le moteur qui

exécute le virement). On suit le trajet de gauche à droite.

Chaîne des composants — du clic au règlement



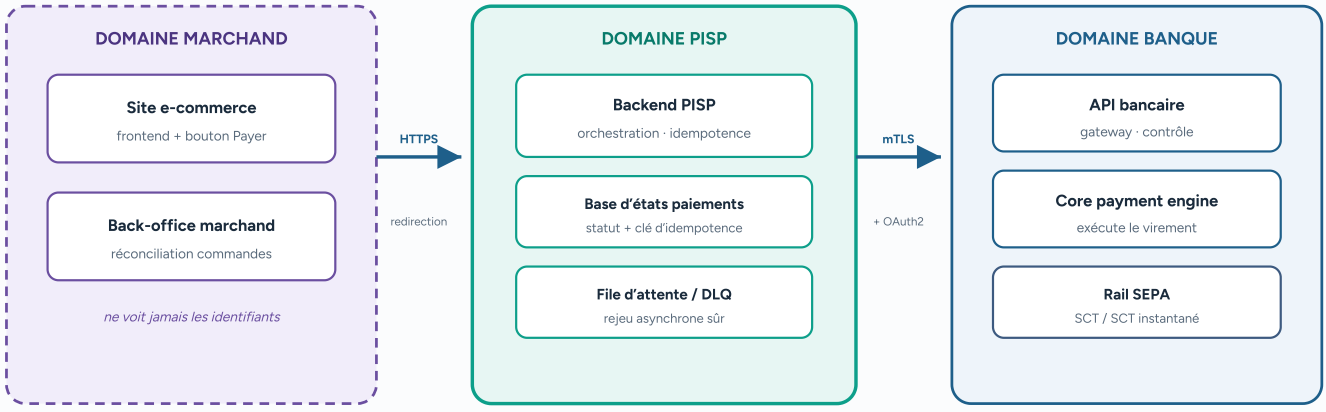
Le PISP est le seul maillon qui voit toute la chaîne : il relaie l'expérience du marchand et appelle l'API de la banque.

DÉPLOIEMENT

Qui héberge quoi : trois zones de confiance

Les quatre composants ne vivent pas au même endroit. Ils se répartissent en **trois domaines de confiance distincts** : le marchand, le PISP et la banque. Chacun contrôle ses propres systèmes ; les échanges entre zones passent par des canaux sécurisés (HTTPS côté marchand, mTLS + OAuth2 côté banque).

Diagramme de déploiement — zones de confiance



Chaque zone a ses propres secrets et périmètres : le marchand ne parle jamais directement à la banque, il passe par le PISP.

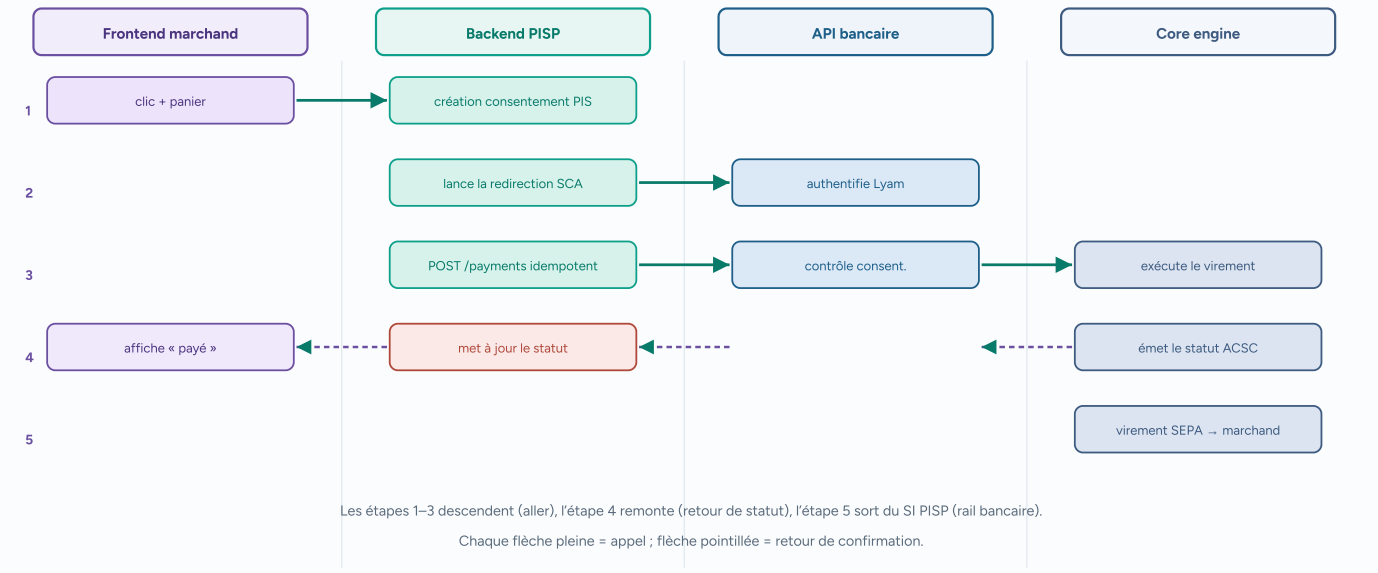
Marchand et banque ne communiquent jamais directement : le PISP est le carrefour, et chaque frontière (HTTPS, mTLS) est un point de contrôle.

FLUX SUR L'ARCHITECTURE

Le flux, projeté sur les composants

Le schéma précédent montre *qui* existe ; celui-ci montre *comment une requête le traverse*. Les quatre composants sont en colonnes, et chaque étape du paiement allume la ou les colonnes concernées, de haut en

bas.



Lire une ligne = une étape ; lire une colonne = la charge d'un composant. On voit d'un coup d'œil que le backend PISP travaille à chaque étape.

COMPOSANT 1

Le frontend marchand

C'est la surface visible : le bouton « Payer par virement » sur le site du marchand. Son rôle est **minimal mais critique** : déclencher, puis rediriger. Il ne doit contenir aucun secret et ne doit jamais manipuler directement l'argent.

Ce qu'il fait

- Propose le moyen de paiement et capture l'intention.
- Redirige Lyam vers le PISP (ou l'écran de SCA).
- Affiche le retour : succès, échec, en attente.
- Reste **idempotent** : rafraîchir la page ne doit pas relancer un paiement.

Ce qu'il ne fait jamais

- Collecter des identifiants bancaires.
- Calculer ou décider du montant final seul.
- Considérer « retour à l'écran succès » comme un paiement confirmé.
- Stocker des données de paiement sensibles côté navigateur.

Le piège du retour de redirection

À la fin du parcours, Lyam revient sur le site du marchand avec une URL « de retour ». Cette URL **n'est pas une preuve de paiement** : elle peut être rejouée, ou ouverte avant que la banque n'ait réellement exécuté. Le marchand doit confirmer via le **backend**, jamais via le front.

COMPOSANT 2

Le backend PISP

C'est **le cerveau de la chaîne**. Il orchestre le consentement, appelle l'API de la banque, suit le statut et rend le résultat au marchand. C'est ici que se concentrent les garanties techniques non négociables.

RESPONSABILITÉ	POURQUOI C'EST VITAL
Tenue du consentement PIS	Un paiement = un consentement, valable un court instant
Appels à l'API PIS	Créer et suivre le paiement auprès de la banque
Idempotence de bout en bout	Un rejeu réseau ne doit pas créer un second virement
Machine à états du paiement	RCVD → PDNG → ACSC/RJCT, avec polling ou notifications
Réconciliation	**Rapprocher le virement reçu de la commande via la référence**

IDÉE DIRECTRICE

Le backend PISP ne détient jamais l'argent : il détient la vérité du statut. Toute la valeur — et toute la sécurité — d'un PISP repose sur une machine à états fiable et une idempotence sans faille.

COMPOSANT 3

L'API bancaire (ASPSP)

C'est la **porte d'entrée de la banque** : le PISP l'appelle via mTLS et OAuth2. Elle contrôle, puis transmet l'ordre au moteur interne. C'est le **point de contrôle réglementaire** de la banque.

Authentifier l'appelant

- mTLS + certificat eIDAS.
- Le PISP est-il un TPP agréé ?
- Pas de certificat valide → **rejet immédiat**.

Valider le consentement

- Le consentement PIS existe-t-il ?
- Bon montant, bon bénéficiaire ?
- Hors périmètre → **403**.

Router vers le core

- Contrôles passés → transmission.
- Vers le **core payment engine**.
- Qui exécute le virement.

API vs core : ne pas confondre

L'**API** est la façade exposée aux TPP (authentification, contrôle, formatage). Le **core** est le système interne qui tient les comptes et exécute. *L'API protège et traduit ; le core exécute.*

COMPOSANT 4

Le core payment engine

C'est le **moteur interne de la banque**. Le PISP ne le voit jamais : il ne voit que ce que l'API lui renvoie. Mais c'est là que l'argent bouge réellement.

1. **Débit du compte**
   Vérification de provision, puis écriture comptable.
2. **Émission du virement**
   Génération de l'ordre SCT / SCT instantané.
3. **Présentation au rail**
   Envoi au système SEPA (compensation).

4 **Retour de statut**

ACSC, RJCT… remonté vers l'API, puis le PISP.

Le core est l'exécutant, pas le décideur

Séparer **contrôle** (API) et **exécution** (core) est une exigence de sécurité : un composant exposé à l'extérieur ne doit jamais avoir accès directement à l'écriture comptable.

CONTRAINTES

Les trois contraintes non négociables

Une architecture PISP ne se juge pas sur son élégance, mais sur sa capacité à tenir trois promesses quand ça va mal : être **disponible**, être **rapide**, et **gérer les rejets**.

1 · Disponibilité

- Le bouton ne mène **jamais** à une page d'erreur.
- Indispo = panier perdu → **redondance + failover**.
- Repli vers un autre moyen de paiement.

2 · Latence

- Chaque seconde d'attente = abandons.
- Appels core / SEPA **asynchrones**.
- Répondre vite, confirmer ensuite (polling / notification).

3 · Gestion des rejets

- Rejet ≠ erreur technique.
- Distinguer **RJCT métier** d'un échec technique.
- Toujours proposer une alternative au client.

→ **Disponible**

Redondance, failover, file d'attente de secours — sinon bouton mort et ventes perdues.

→ **Rapide**

Asynchronisme, polling, notifications — sinon abandon au premier délai.

→ **Rejets maîtrisés**

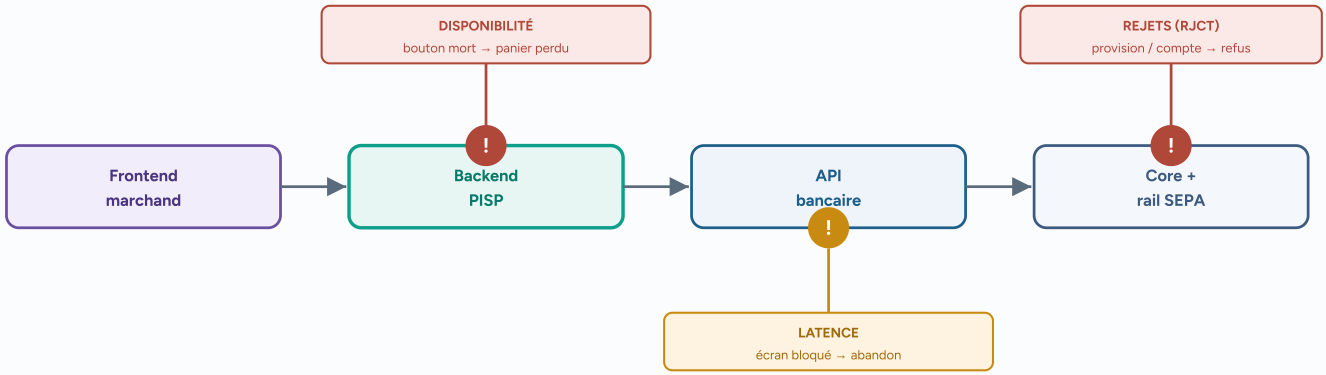
Machine à états, distinction RJCT/erreur, repli de paiement — sinon client bloqué sans issue.

CONTRAINTES EN IMAGE

Où la chaîne casse quand une contrainte lâche

Chaque contrainte a un **point de défaillance** privilégié sur la chaîne : c'est là qu'il faut placer la parade.

Points de défaillance par contrainte



Disponibilité et rejets touchent la chaîne d'exécution ; la latence se joue au point d'appel externe (API).

Repérer le point de défaillance, c'est savoir où mettre la parade : redondance pour la disponibilité, asynchronisme pour la latence, machine à états pour les rejets.

GARDE-FOUS

Le workflow anti-incident d'un PISP

Une fois le virement parti, l'ordre des opérations compte. Ces six garde-fous se construisent **ensemble** : les ajouter après coup coûte des semaines — et parfois des doublons en production.

1. **Idempotence**
   Une clé à l'initiation, stockée côté backend : un rejeu (timeout, retry) ne crée jamais un second virement.
2. **Machine à états**
   États explicites (RCVD, PDNG, ACSC, RJCT…) et transitions contrôlées ; on ne devine jamais un statut.
3. **Asynchronisme**
   Le 202 « reçu » n'est pas le paiement : confirmation par polling ou notification, tous deux idempotents.
4. **File de secours (DLQ)**
   Si le core ou le rail ne répond pas, les ordres sont mis en file et rejoués — jamais perdus.
5. **Réconciliation**
   Rapprochement virement ↔ commande via la référence, pour détecter les écarts avec la trésorerie réelle.
6. **Observabilité**
   Traçage de bout en bout (corrélation par identifiant) pour reconstituer un parcours et trancher un litige.

SÉQUENCE SUIVANTE

Et avec trois API ?

On a construit le SI d'un PISP. Mais un TPP ne s'arrête pas à un usage strict : il combine l'AIS, le PIS et le CBPII pour fabriquer des services qu'aucune des trois API ne rend seule. La S4 passe en revue ce que cette combinaison permet — et ce qu'elle coûte.

05 · S4 · APPLICATIONS ET CAS CONCRETS

S4 - Applications et cas concrets

TROIS API, BEAUCOUP DE PRODUITS

Combiner les API

AIS, PIS et CBPII ne sont pas trois produits concurrents : ce sont trois briques. Les TPP qui comptent ne s'en tiennent pas à l'usage strict d'une API — ils les associent pour fabriquer des services qu'aucune des trois ne rend seule.

FIL ROUGE

Lyam a payé son vase par virement PISP. C'était un paiement complet, mais un paiement *seul*. Le vrai terrain de jeu commence quand un service veut **savoir**, **payer** et **garantir** au même moment. Cette séquence sort du fil PISP pour regarder ce que les TPP construisent avec les trois API.

PRINCIPE

Des briques, pas des produits

Chaque API de la DSP2 répond à une question précise. Prise seule, elle ne suffit jamais à faire un service commercial. À l'intersection, il y a de la valeur.

API	QUESTION À LAQUELLE ELLE RÉPOND	CE QU'ELLE NE FAIT PAS
AIS — information sur les comptes	« Que contient le compte du client ? »	Ne déplace pas d'argent, n'engage aucune promesse
PIS — initiation de paiement	« Peut-on déclencher un virement ? »	Ne vérifie pas le solde avant, ne garantit pas le succès
CBPII — confirmation de fonds	**« Y a-t-il la provision, maintenant ? »**	**Ne réserve pas les fonds, ne paie rien**

La nuance qui change tout

Le CBPII ne **réserve** rien : il répond « oui, le solde couvre » à un instant donné. Entre cette réponse et le virement effectif, le solde peut changer. Toute architecture qui empile CBPII puis PIS doit assumer ce décalage — c'est le cœur du risque, et l'essentiel du travail d'ingénierie.

Un TPP n'est pas un canal, c'est un assembleur

Un TPP agréé peut avoir plusieurs casquettes : AISP, PISP, CBPII. Son produit n'est pas « l'API bancaire exposée » — c'est l'orchestration de plusieurs appels bancaires, enrichis de données propres (scoring, catalogue, comptabilité, garantie) qu'il ajoute par-dessus.

MOTIF 1

« Payer en un clic » — savoir avant de payer

Le paiement par virement impose au client de choisir sa banque puis de s'authentifier, sans savoir si le compte couvre la dépense. La combinaison **AIS** → **CBPII** → **PIS** supprime cette incertitude : on observe, on confirme la provision, puis on initie.

1 **AIS — lire le compte**

Le TPP récupère les comptes et le solde disponible du client, avec un consentement AIS. Il peut afficher « Compte courant — Banque Est : 340,20 € ».

2 **CBPII — confirmer la provision**

Pour le montant exact du panier, le TPP demande au compte s'il couvre la dépense. La réponse est un oui/non, valable à l'instant *t*.

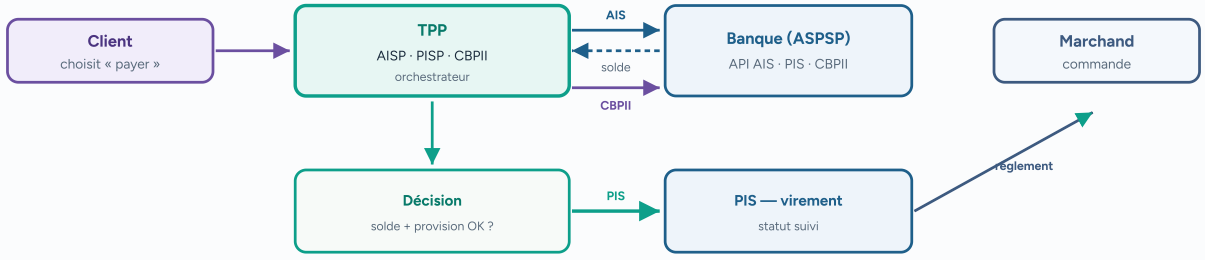
3 **PIS — initier le virement**

Le TPP déclenche le virement du compte vers le marchand, avec le montant et la référence de commande convenus.

4 **Réconciliation**

Le TPP suit le statut PIS et rapproche le virement reçu de la commande, via la référence. C'est ce qui ferme la boucle côté marchand.

Chaîne d'appels — « Payer en un clic »



Le CBPII confirme à l'instant t — le solde peut bouger avant l'exécution du PIS.

Ce que ça apporte

Le client voit immédiatement s'il peut payer, et le marchand réduit les virements rejetés faute de provision. L'expérience se rapproche de la carte, sans changer de rail.

Ce que ça risque

La confirmation CBPII n'est pas une réservation. Entre la réponse et l'exécution, un autre débit peut passer. Le TPP doit donc gérer un échec tardif, pas le cacher au client.

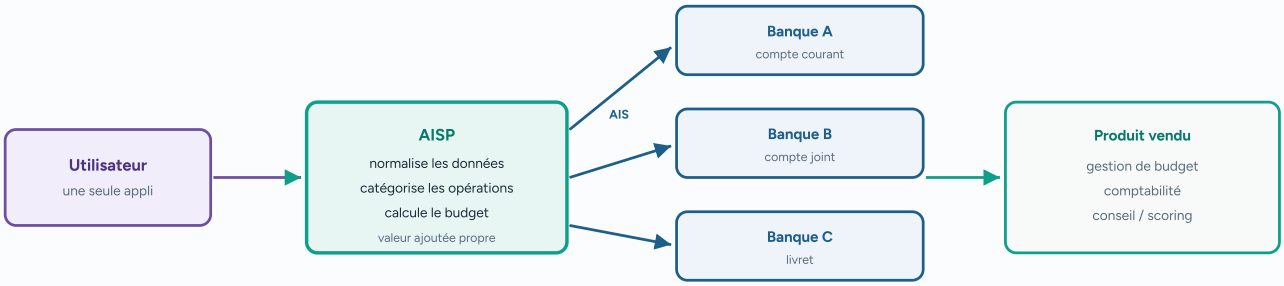
MOTIF 2

« Compte enrichi » — agréger pour vendre un autre produit

Le cas le plus courant chez les AISP : réunir plusieurs comptes bancaires dans une seule vue, puis transformer cette donnée en service — budget, comptabilité, scoring, conseil. Le PIS vient souvent en complément, pour

agir sur les comptes agrégés.

Architecture — agrégation multi-banques



Un consentement AIS par banque · durée limitée · renouvellement à la main du client.

Le vrai métier n'est pas l'API

Récupérer des soldes ne vaut rien : des milliers d'applications savent le faire. Ce qui fait le produit, c'est la **normalisation** entre banques, la **catégorisation** des libellés et la **restitution** dans une décision utile. L'API est le carburant ; le produit, c'est le moteur.

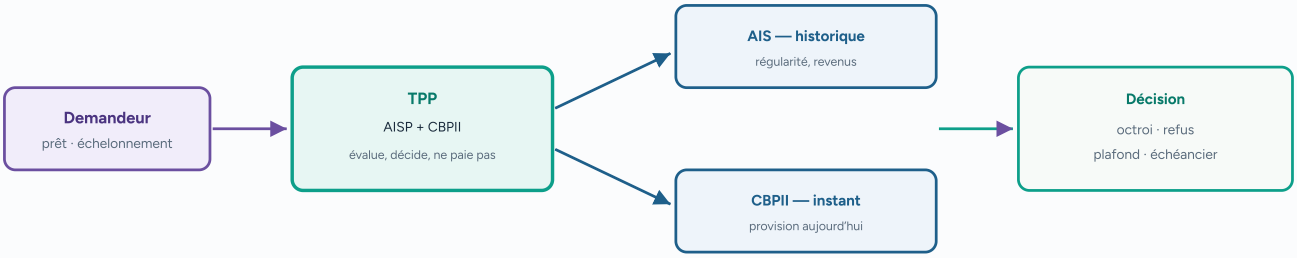
USAGE	API MOBILISÉE	VALEUR AJOUTÉE PAR LE TPP
Agrégateur de comptes	AIS	Normalisation multi-banques, catégorisation
Outil de gestion / compta	AIS + PIS	Rapprochement, écritures, virements fournisseurs
Conseil financier	AIS	Analyse de dépenses, recommandations
Vérification de revenus	**AIS**	**Scoring, preuve de ressources pour un tiers**

MOTIF 3

« Vérification instantanée » — décider sans payer

Beaucoup de services ne veulent pas encaisser : ils veulent **savoir** avant de s'engager. Prêt, paiement échelonné, prise en charge par un tiers : le CBPII suffit, combiné à l'AIS, sans jamais déclencher de virement.

Architecture — vérification de capacité, sans mouvement de fonds



Aucun ordre de virement — le TPP observe et confirme, puis le règlement se fait par un autre moyen.

Attention à la nature du CBPII

Le CBPII a été conçu pour le *bénéficiaire d'un paiement* (typiquement une entreprise qui veut savoir si un virement va passer). Le détourner vers du crédit à la consommation pose des questions de cadre : ce n'est pas parce que l'appel est techniquement possible que l'usage est dans le périmètre de l'agrément.

MOTIF 4

« API détournée » — quand le consentement sert d'autre chose

Le cas le plus intéressant pédagogiquement : le TPP utilise l'AIS comme **preuve** — pas pour afficher un solde, mais pour attester d'un fait à un tiers. Le consentement AIS devient un instrument de vérification d'identité financière.

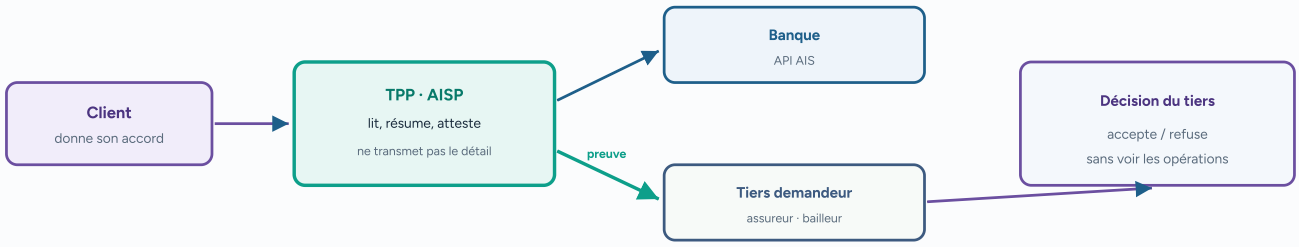
Vérification de compte

Le demandeur (assureur, plateforme, bailleur) veut s'assurer que l'IBAN déclaré appartient bien à la personne. Le TPP confirme que le compte existe chez cette banque, sans transmettre les opérations.

Preuve de revenus

Le TPP lit les virements entrants récurrents et en déduit un revenu régulier. Le client choisit de partager ou non cette synthèse. L'AIS remplace ici la liasse de fiches de paie.

Architecture — le consentement comme preuve



Le tiers ne parle jamais à la banque — il fait confiance à l'attestation du TPP.

La ligne rouge

Ce détournement est légitime tant que le consentement reste explicite, limité dans le temps et proportionné à l'usage : lire les revenus pour un prêt, oui ; lire tout l'historique pour un service qui n'en a pas besoin, non. Le RGPD et la DSP2 se rejoignent ici sur la **minimisation**.

SYNTHÈSE

Quatre motifs, une même logique

Ces quatre motifs ne sont pas des recettes à réciter : ce sont des *formes* d'assemblage. Un produit réel en

combine souvent deux, et en ajoute un troisième qu'on n'avait pas anticipé.

MOTIF	API COMBINÉES	LE TPP APPORTE	RISQUE PRINCIPAL
Payer en un clic	AIS + CBPII + PIS	Orchestration, assurance de provision	Provision non réservée
Compte enrichi	AIS (+ PIS)	Normalisation, catégorisation, analyse	Renouvellement des consentements
Vérification instantanée	AIS + CBPII	Scoring, décision de crédit	Périmètre de l'agrément
API détournée	**AIS (comme preuve)**	**Attestation, synthèse**	**Minimisation des données**

Repères factuels

Les produits évoqués ici le sont par **catégorie d'acteur** (agrégateur, échelonnement de paiement, outil de gestion) et non par marque. Tous ne s'appuient pas exclusivement sur la DSP2 : certains combinent API bancaires, accords bilatéraux et données propres. Ce qui est transférable, c'est le **motif d'architecture**, pas la fiche produit.

1. **Une API ne fait jamais un produit**
   Elle répond à une question. Le produit naît de la deuxième question, et de la façon de les enchaîner.
2. **La valeur est dans l'enrichissement**
   Normaliser, catégoriser, scorer, attester : c'est là que se crée la différence entre deux TPP sur la même API.
3. **L'agrément borne l'imagination**
   Techniquement possible n'égale pas autorisé. Chaque motif doit tenir dans le périmètre de l'agrément et du RGPD.

CLÔTURE DU JOUR 3

Trois API, et pourtant beaucoup de produits

Le paiement initié était le fil rouge de la journée : AIS, PIS et CBPII sont en réalité trois briques que les TPP combinent pour fabriquer des services qu'aucune ne rend seule. Comprendre ces combinaisons, c'est comprendre pourquoi l'Open Banking est une *infrastructure*, pas une fonctionnalité. Le Jour 4 change de question : et si l'on appliquait cette logique à la **donnée** elle-même ?